江西省应急管理厅
统一身份认证规范

江西省应急管理厅　　发 布

目 录

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

3.1 JS 对象简谱 JAVASCRIPT OBJECT NOTATION 1
3.2 HTTP 传输协议 1
3.3 HTTPS 传输协议 1
3.4 URLENCODE 2
3.5 SSO 2
3.6 RABBITMQ 2
4.1 同步数据范围 3
4.2 接入方式 3
4.3 接入流程 3

5 统一身份认证系统 4

5.1 统一身份认证接入流程 4
5.2 工作要求 4
5.3 接口主要功能 5
5.4 身份核验 5
5.4.1 认证流程 5
5.5 单点登录 5
5.5.1 单点登录流程 6
5.5.2 单点登出流程 8

6 统一授权接入 9

6.1 接入方式 9
6.2 接入流程 9

附 录 A （规范性附录） 统一用户接入消息接口附录 11

A.1 基本消息体 11
A.2 消息类型 11
A.3 字段说明 12

附 录 B （规范性附录） 系统接入用户数据申请表 15

B.1 系统接入用户数据申请表 15

附 录 C （规范性附录） 身份核验类接口示例及说明 16

C.1 身份核验表 16

附 录 D （规范性附录） 单点登录类接口示例及说明 17

D.1 验证用户是否登录、获取 TICKET 接口表 17
D.2 验证 TICKET 合法性、获取用户信息接口表 17
D.3 用户退出接口表 18

附 录 E （规范性附录） 服务接口调用类接口示例及说明 19

E.1 用户信息获取接口表 19
E.2 用户登录接口表 21

附 录 F （规范性附录） 应用系统登录/登出示例及说明 1

F.1 判断是否登录 1
F.2 临时票据判断 2
F.3 SSO 登录接口 3
F.4 退出登录 4

附 录 G （规范性附录） 统一授权接入消息接口附录 1

G.1 基本消息体 1
G.2 人员对象 1
G.3 机构对象 2
G.4 角色对象 3
G.5 角色菜单对象 3
G.6 角色人员对象 3
G.7 菜单对象 3
G.8 租户对象 4
G.9 租户菜单对象 4
G.10 新增角色消息 4
G.11 修改角色消息 5
G.12 删除角色消息 5
G.13 新增角色菜单消息 5
G.14 删除角色菜单消息 5
G.15 新增角色人员消息 6
G.16 删除角色人员消息 6
G.17 新增菜单消息 6
G.18 修改菜单消息 6
G.19 删除菜单消息 6
G.20 新增租户消息 7
G.21 修改租户消息 7
G.22 删除租户消息 7
G.23 新增租户菜单消息 7
G.24 删除租户菜单消息 7

前　言

本规范按照 GB/T1.1-2020 《标准化工作导则 第一部分：标准化文件的结构和起草规则》的规定编写。

本规范由江西省应急管理厅提出并归口。

本规范主要起草单位：江西省水投江河信息技术有限公司。

本规范校准单位：江西省应急管理厅。

江西省应急管理厅
统一身份认证规范

1 范围

本规范规定了全省应急用户信息管理系统的总体架构、接入方式、接入流程和建设规范。

本规范适用于指导各智慧应急应用对全省应急用户信息管理系统建设工作的规划、制定、修订、应用与管理等工作。

2 规范性引用文件

3 术语和定义

下列术语和定义适用于本文件。

3.1 JS 对象简谱 Javascript object notation

JSON(JavaScript Object Notation, JS 对象标记）是一种轻量级的数据交换格式。它基于ECMAScript(w3c 制定的 js 规范)的一个子集，采用完全独立于编程语言的文本格式来存储和标识数据。简洁和清晰的层次结构使得 JSON 成为立项的数据交换语言。易于人阅读和编写，同时也易于机器解析和生成，并有效的提升网络传输效率。

3.2 HTTP 传输协议

http 是标准超文本传输协议。使用对参数进行编码并将参数作为键值对传递，还使用关联的请求语义。每个协议都包含一系列 HTTP 请求标头及其他一些信息，定义客户端向服务器请求哪些内容，服务器用一系列 HTTP 响应标头和所请求的数据进行响应。HTTP-GET 使用 MIME 类型 application/x-www-form-urlencoded（将追加到处理请求的服务器的 URL 中）以 URL 编码文本的形式传递其参数。 URL 编码是一种字符编码形式，可确保传递的参数中包含一致性文本，例如将空格编码为 20%，其它符号转换为%XX,其中 XX 为该符号以 16 进制表示的 ASCII（或 ISOLatin-1）值。追加的参数也称为查询字符串;HTTP-POST 参数也是 URL 编码的，但是，键/值对是在实际的 HTTP 请求消息内部传递的，而不是作为 URL 的一部分进行传递。。

3.3 HTTPS 传输协议

HTTPS（全称：Hyper Text Transfer Protocol over Secure Socket Layer），是以安全为目标的 HTTP 通道，简单讲是 HTTP 的安全版。即 HTTP 下加入 SSL 层，HTTPS 的安全基础是 SSL，因此加密的详细内容就需要 SSL。它是一个 URI scheme（抽象标识符体系），句法类同 http:体系。用于安全的 HTTP 数据传输。https:URL 表明它使用了 HTTP，但 HTTPS 存在不同于 HTTP 的默认端口及一个加密/身份验证层（在 HTTP 与 TCP 之间）。这个系统的最初研发由网景公司(Netscape)进行，并内置于其浏览器 Netscape Navigator 中，提供了身份验证与加密通讯方法。现在它被广泛用于万维网上安全敏感的通讯。

3.4 UrlEncode

UrlEncode 是一个函数，可将字符串以 URL 编码，用于编码处理。URL 编码(URL encoding)，也称作百分号编码(Percent-encoding)，是特定上下文的统一资源定位符 (URL)的编码机制。适用于统一资源标识符(URI)的编码，也用于为"application/x-www-form-urlencoded" MIME 准备数据，因为它用于通过 HTTP 的请求操作(request)提交 HTML 表单数据。

3.5 SSO

单点登录（Single Sign On），简称为 SSO，是目前企业业务整合的首选方案，是比较流行的解决方案。SSO 的功能是在多个应用系统中，用户只需要登录一次就可以访问所有相互信任的应用系统。

3.6 RabbitMQ

RabbitMQ 是实现了高级消息队列协议（AMQP）的开源消息代理软件（亦称面向消息的中间件），是一个由 Erlang 语言开发的 AMQP（Advanced Message Queue） 的开源实现，用于在分布式系统中存储转发消息，在易用性、扩展性、高可用性等方面表现不俗。

4 统一用户接入

4.1 同步数据范围

根据智慧应急建设要求，所有人员、机构数据必须从人员管理系统统一获取，应急人员信息管理系统（以下简称人员管理系统，又称HR系统）实现了对省应急厅及下属各级单位主要组织机构、人员信息的管理并提供了共享，为各应用系统获取组织结构及人员信息提供了支撑。接入申请审批通过后，HR管理员在系统应用管理功能下添加资源,配置允许分配范围下的组织人员信息,相应系统完成消息对接，用户信息发生变更可同步获取范围下人员的基本信息、人员对应组织机构信息。

4.2 接入方式

业务系统同步用户数据可申请系统管理员在人员管理系统应用资源下添加配置,系统分配授权码及消息队列名。系统订阅RabbitMQ消息实时与人员管理系统进行同步。业务系统共用一套用户体系，以保证江西应急组织机构及人员信息高度一致。RabbitMQ介于人员管理系统与应用系统之间，是两方系统用户数据传递的纽带，建议进行同步的MQ账号密码针对不同应用独立分发并区分账号权限，人员管理系统用户数据发生变更后会把用户数据放在约定的队列中，应用系统订阅消费队列更新对应用户数据。

业务系统同步HR用户数据需本地持久化存储,应用系统针对接收到用户不同消息类型要有不同处理方式。新增人员消息中如果该人员已经存在，则修改该人员信息；如果该人员没有授权部门，则删除该人员；删除人员建议使用逻辑删除，人员重新授权后会推送新增人员信息。应用系统需增加异常处理机制以保证成功消费的数据都成功更新入库。

4.3 接入流程

业务系统向江西省应急厅人员管理系统管理员提供系统名称、系统简称、系统地址、系统 LOGO,系统管理员在应用管理功能下配置完成用户体系接入，申请表参见附录 B(系统接入用户数据申请表)。建立用户数据同步机制。在人员管理系统应用管理维护对应的人员范围信息，业务系统按生成的消息队列订阅消息即可完成变更用户消息数据同步。

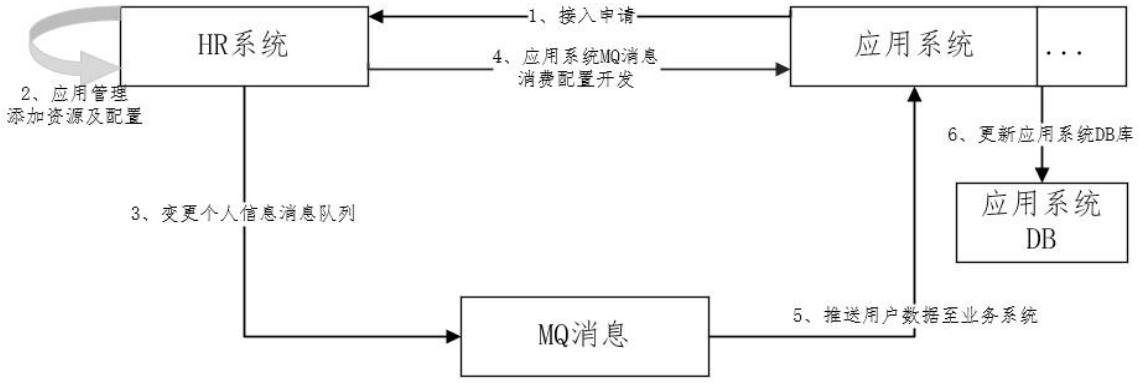


图 1 应用系统用户接入流程

a）应用系统发起接入申请；

b）管理员进入人员管理系统，点击进入应用管理；

c）在应用管理下点击添加应用资源，配置应用信息、人员范围及分配 MQ 消息队列名；

d）应用系统系统开发配置，订阅分配的 MQ 消息队列消息；

e）用户信息发生变更后，应用系统消费用户数据；

f）变更用户数据更新入库，数据入库要保证数据最终一致性。

5 统一身份认证系统

5.1 统一身份认证接入流程

在全省应急用户管理系统以管理员身份登录为待接入系统添加资源为其分配授权码、客户端 id、客户端秘钥等资源信息（或者以普通用户登录全省管理系统申请新增资源），之后用户获取某个用户在该系统内所拥有的权限点时可携带令牌以该“授权码”为配置参数获取相对应接入系统的资源、解密公钥等信息。

在需要接入统一认证的业务系统内按需引入对应协议的“资源中心客户端组件”并且参照组件说明文档进行详细配置即可接入统一认证平台，接入统一认证平台后各业务系统即可携带从认证中心中获取到的令牌做到统一认证实现“实现一处登录可以访问所有相互信任的应用系统”目的。

5.2 工作要求

统一身份认证系统采用先进信息技术，解决系统建设中的关键技术问题，确保系统的先进性、标准规范性、安全稳定性和易管理性。应紧密结合各应用子集建设现状，有效利用既有投资，紧扣政府部门科学决策、高效联动、精细化服务的业务需求，以及社会公众对公共服务的多层次、多元化的需求，在保证系统先进性、标准性的同时，又不失实用性、灵活性以及可扩展性。

5.3 接口主要功能

统一身份认证系统数据接口主要包括以下功能：

a） 身份认证；

b） 单点登录；

c） 服务接口调用；

5.4 身份核验

系统提供完善的用户身份认证功能，满足不同应用场景的用户信息认证要求，为增加调用接口返回数据的易读性，统一格式为标准 JSON 格式，以保障系统间正常数据抓取。

5.4.1 认证流程

身份核验能够对用户进行身份认证，接口调用方调用身份核验接口来进行身份认证。如图 3 所示

a） 用户输入用户名、密码从认证中心获取令牌(token)；

b） 认证通过后由认证中心颁发令牌；

c） 客户端携带令牌 token 请求业务系统获取资源；

d） 业务系统内使用资源服务组件内提供的过滤器或者去鉴权中心校验令牌的合法性（该步骤根据协议不同有差异 oauth2 协议为调用接口验证， jwt 规范为过滤器验证）；

e） 合法即返回资源信息；

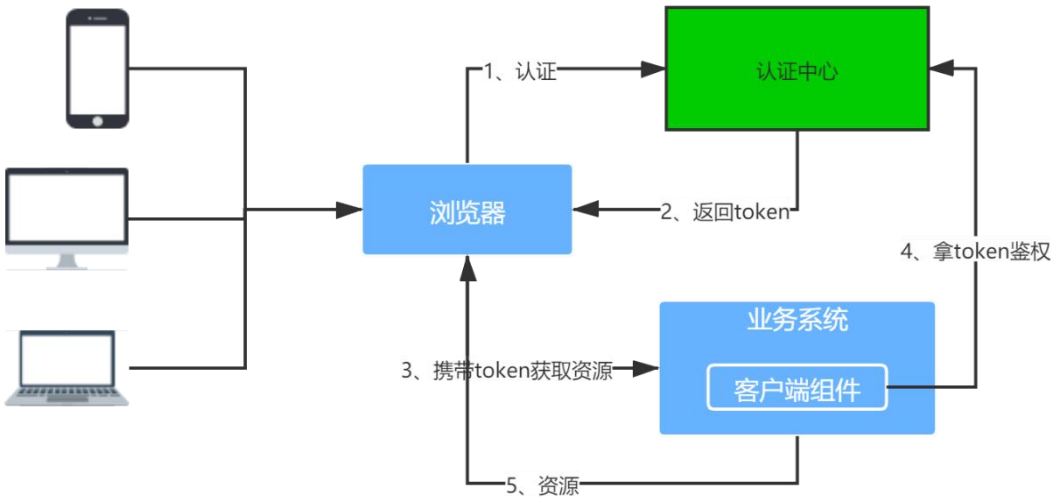


图 2 身份校验图

5.5 单点登录

系统提供单点登录服务，满足在多个应用系统中，用户只需要登录一次就可以访问所有相互信任的应用系统，一次登出其他系统同时退出。本系统统一认证的基础按照 cas 协议来实现单点登录、登出功能。

5.5.1 单点登录流程

相比单体应用登录，实现单点登录需要一个独立的认证中心，负责接受用户信息的验证请求，其他系统不提供登录入口，只接受认证中心的间接授权。间接授权通过令牌实现，认证中心验证用户的登录信息正确后，创建授权令牌，在接下来的跳转过程中，授权令牌作为参数发送给各个子系统，子系统拿到令牌后将再次回传给认证中心认证，校验授权令牌完成后，将用户的会话回传给子系统，实现登录。为保证安全性要求统一认证中心使用 https 协议进行数据传输，具体流程如下图 3 所示。

a) 用户访问系统 A 受保护资源，系统 A 发现用户未登录，将自己的地址 UrlEncode 后作为参数跳转至 sso 认证中心。

b) SSO 认证中心发现用户未登录，跳转至登录页面。

c) 用户选择钉钉扫码登录、用户名密码登录、短信验证码登录三种认证方式的任意一种，提交登录申请。

d) SSO 认证中心校验用户信息，创建用户与 SSO 认证中心之间的全局会话，全局令牌(和用户全局会话 ID 绑定，代表用户在 SSO 登录)和临时令牌(用于验证子系统身份)。

e) SSO 认证中心携带令牌跳转系统 A 最初的请求地址。

f) 系统 A 拿到令牌，去 SSO 认证中心校验令牌是否有效。

g) SSO 认证中心校验令牌，回传用户全局会话。

h) 系统 A 保存用户的全局会话。

i) 用户浏览器显示登录成功。

j) 再次登录流程分析：

k) 用户访问系统 B 的受保护资源。

l) 系统 B 发现用户未登录，跳转至 SSO 认证中心，并将自己的地址作为参数。

m) SSO 认证中心发现用户已登录，跳转回系统 B 的地址，并附上令牌。

n) 系统 B 拿到令牌，去 SSO 认证中心校验令牌是否有效。

o) SSO 认证中心校验令牌，返回用户全局会话。

p) 系统 B 保存用户全局会话。

q) 用户浏览器显示登录成功。

r） 用户输入用户名、密码从认证中心获取令牌(token)；

s） 认证通过后由认证中心颁发令牌；

t） 客户端携带令牌 token 请求业务系统获取资源；

u） 业务系统内使用资源服务组件内提供的过滤器或鉴权中心校验令牌的合法性（该步骤根据协议不同有差异）；

v） 合法即返回资源信息；

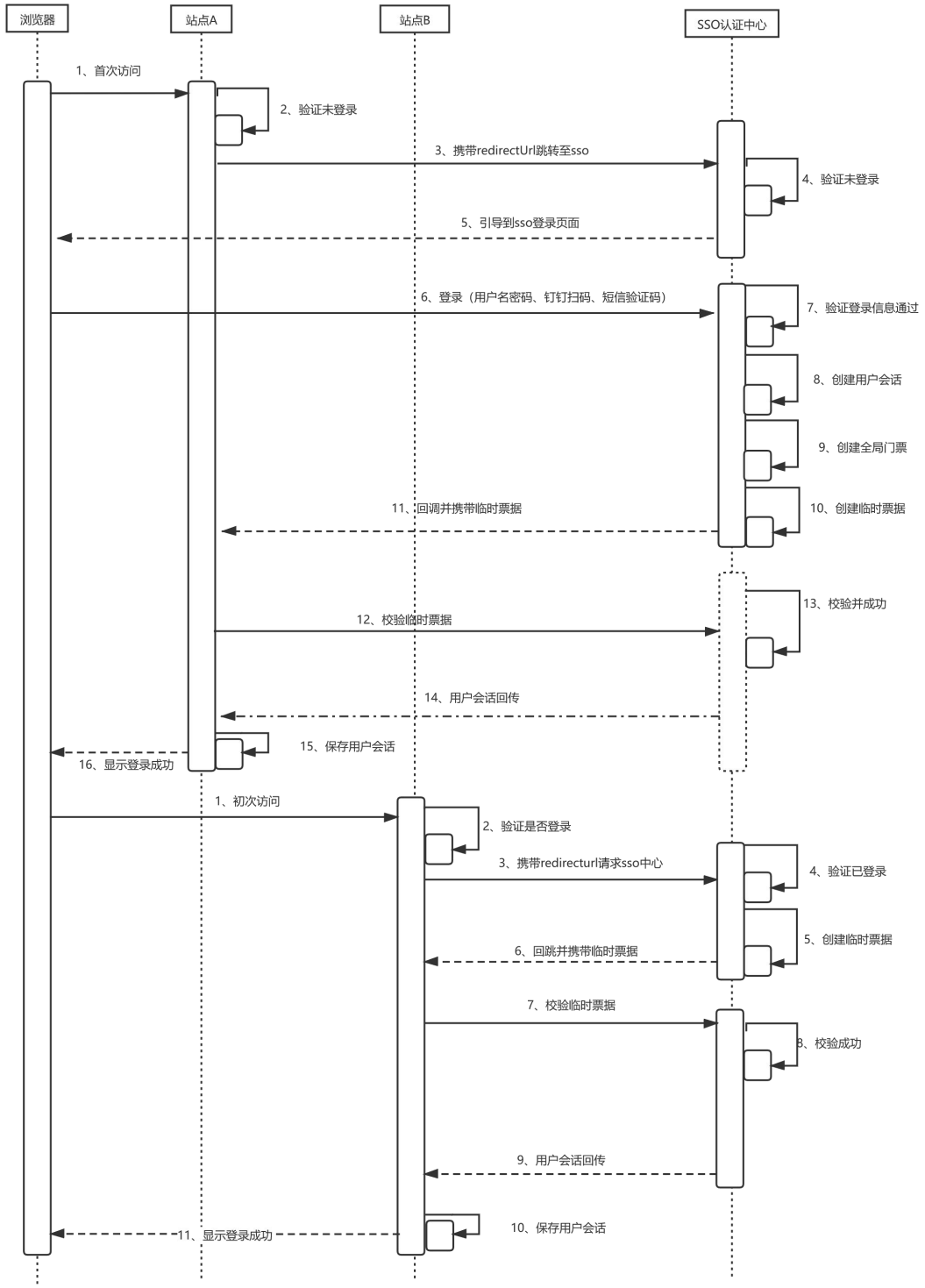


图 3 单点登录流程图

5.5.2 单点登出流程

与单点登录同理，实现单点登出也需要借助统一认证中心来完成，用户在任意按照单点接入规范进行对接的系统内退出登录，在其他按照单点登录规范进行对接的系统内也应该变成登出状态。具体流程

如下图 4 所示。

a) 用户向系统 A 发起注销请求；

b) 系统 A 根据用户与建立的会话 id 拿到令牌，向 SSO 认证中心发起注销请求；

c) SSO 认证中心校验令牌有效，销毁全局会话；

d) SSO 认证中心引导用户至登录页面。

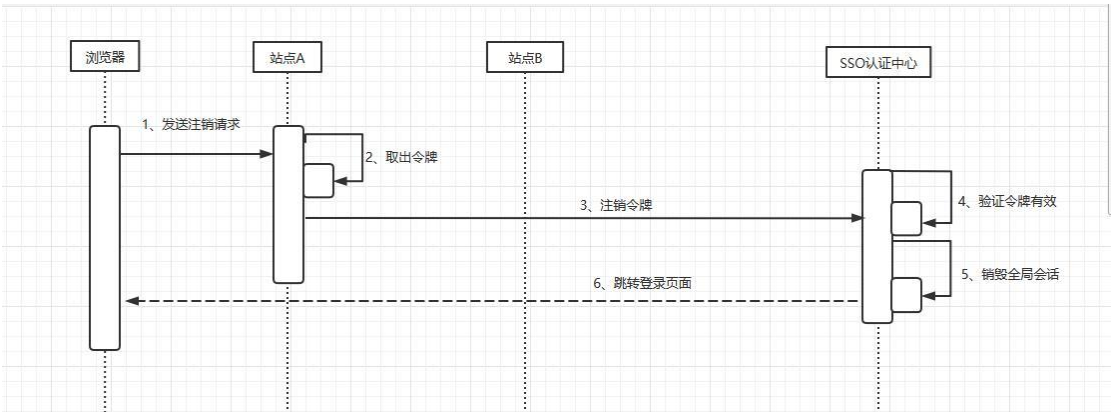


图 4 注销登录流程图

6 统一授权接入

6.1 接入方式

根据智慧应急建设要求，所有应用系统为避免重复建设角色权限等相关功能，需统一在应用支撑平台中管理应用系统的角色、菜单、用户权限等，为了使应用系统能同步数据，使用RabbitMQ作为中间件。RabbitMQ介于应用支撑平台与应用系统之间，是两方系统角色权限数据传递的纽带，应用支撑平台角色权限数据发生变更后会把角色权限数据放在约定的队列中，应用系统订阅消费队列更新对应数据。业务系统接收到用户消息数据后，根据消息的数据类型，对应的对数据进行新增、修改或删除。

6.2 接入流程

业务系统通过应用支撑平台租户管理、角色管理等功能配置应用系统的权限数据。

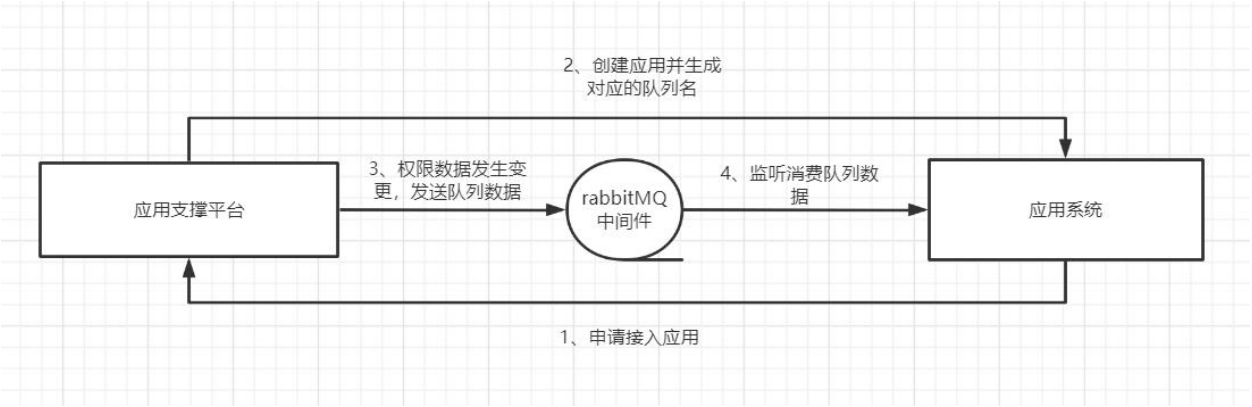


图 5 授权接入流程

a）应用系统发起接入申请；

b）管理员进入应用支撑平台，点击进入应用管理；

c）在应用管理下点击添加应用资源，配置应用信息、人员范围及分配 MQ 消息队列名；

d）应用系统订阅分配的 MQ 消息队列消息；

e）租户、角色、菜单等数据发生变更后，应用系统消费队列数据；

f）变更租户、角色、菜单等数据更新入库。

附　录　A

（规范性附录）

统一用户接入消息接口附录

A.1　基本消息体

```
{
    "time": "消息发送时间",string
    "type": "消息类型",string
    "data": "消息体",string
     “resourceId”:“资源 id”,Long
}
```

A.2　消息类型

a）新增人员消息

参数名	类型	说明	备注
time	string	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	string	消息类型	“101” 为新增人员消息类型
data	string	数据集合（ArrayList）	人员对象列表，详见 A.3 人员对象
resourceId	Long	资源 id	-

b）修改人员消息

参数名	类型	说明	备注
time	string	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	string	消息类型	“102” 为修改人员消息类型
data	string	数据集合（ArrayList）	人员对象列表，详见 A.3 人员对象
resourceId	Long	资源 id	-

c）删除人员消息

参数名	类型	说明	备注
time	string	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	string	消息类型	“103” 为删除人员消息类型
data	string	数据集合	人员对象列表，详见 A.3 人员对象
resourceId	Long	资源 id	-

d) 新增机构消息

参数名	类型	说明	备注
time	string	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	string	消息类型	“201” 为新增机构消息类型
data	string	数据集合（ArrayList）	机构对象列表，详见 A.3 机构对象

e) 修改机构消息

参数名	类型	说明	备注
time	string	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	string	消息类型	“202” 为修改机构消息类型
data	string	数据集合(ArrayList)	机构对象列表，详见 A.3 机构对象
resourceId	Long	资源 id	-

f) 删除机构消息

参数名	类型	说明	备注
time	string	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	string	消息类型	“203” 为删除机构消息类型
data	string	数据集合(ArrayList)	机构对象列表，详见 A.3 机构对象
resourceId	Long	资源 id	-

A.3 字段说明

a) 人员对象

序号	字段 ID	字段中文	字段类型	字段说明
1	id	用户 ID	Long	
2	officeId	部门 ID	Long	
3	officeName	部门名称	String	
4	viceOffices	从部门集合		
4.1	officeId	从部门 ID	Long	循环结构体
4.2	officeName	从部门名称	String	循环结构体
4.3	sort	从部门下排序值	Long	循环结构体
5	loginName	登陆名	String	
6	password	密码(MD5 密文)(32 位小写)	String	
7	no	员工编号	String	
8	name	姓名	String	
9	email	邮箱	String	
10	phone	座机号码	String	
11	mobile	手机号码	String	
12	photo	原始头像	String	
13	remarks	备注	String	
14	userType	用户类型	String	
15	sex	性别	String	(0:未知;1:男;2:女)
16	mobileShort	手机短号	String	
17	sort	主部门下排序值	Long	
18	position	职位(职务)	String	
19	birthday	生日(格式：yyyy-MM-dd)	String	
20	room	房号	String	
21	photoLarge	大头像	String	
22	photoSmall	小头像	String	
23	photoNormal	一般头像	String	
24	idNo	身份证号	String	
25	qqMulti	qq 号码，多个逗号分割	String	
26	weChat	微信号码，多个逗号分割	String	
27	licence	车牌号	String	
28	ipMulti	ip，多个逗号分割	String	
29	officeAddress	办公地址	String	
30	homeAddress	家庭地址	String	
31	homeTel	家庭电话	String	
32	alias	别名	String	
33	password2	密码(DES 密文)	String	
34	signature	个性签名	String	
35	loginFlag	是否可登录	String	(0:该人员禁止登录人员管理系统; 1:该人员允许登录人员管

				理系统)

b) 机构对象

序号	字段 ID	字段中文	字段类型	字段说明
1	id	部门 Id	Long	
2	parentId	父部门 Id	Long	
3	name	部门名称	string	
4	sort	部门排序值	Long	
5	areaName	所属区域	string	
6	areaCode	区域编码	string	
7	code	部门编号	string	
8	address	地址	string	
9	zipCode	邮政编码	string	
10	master	负责人	string	
11	phone	电话	string	
12	fax	传真	string	
13	email	邮箱	string	
14	useable	是否可用	string	(1:是;0:否)
15	remarks	备注	string	
16	orgFlag	机构类型	string	（0:部门，1:j 机构或单位）

附 录 B

（规范性附录）

系统接入用户数据申请表

B.1 系统接入用户数据申请表

系统接入用户数据申请表			
应用名称		申请接入时间	
开发负责人		项目经理	
申请系统地址			
是否紧急	□普通 □紧急		
IP 白名单			
授权范围			
审批意见			
审批人		审批时间	

附 录 C

（规范性附录）

身份核验类接口示例及说明

C.1 身份核验表

服务名称	https://auth.yjglt.jxx.cegn/oauth/check_token	
服务说明	个人身份核验	
请求方式	POST	
参数列表	参数名称	参数说明
	token	令牌

返回值	{
	"code": 1,
	"msg": "用户凭证已过期",
	"data": "Full authentication is required to access this resource"
	}	

附 录 D

（规范性附录）

单点登录类接口示例及说明

D.1 验证用户是否登录、获取ticket接口表

服务名称	https://auth.yjglt.jxx.cegn/login	
服务说明	判断用户是否登录、返回 ticket	
请求方式	GET	
参数列表	参数	参数说明
	returnUrl	回调地址
返回值	返回 tmpTicket 和 returnUrl	
备注		

D.2 验证ticket合法性、获取用户信息接口表

服务名称	https://auth.yjglt.jxx.cegn/verify-tmp-ticket	
服务说明	单点登录时验证 ticket 的合法性，返回用户信息	
请求方式	POST	
参数列表	参数名称	参数说明
	tmpTicket	待校验的票据
返回值	{ "code": 1, "msg": "用户票据异常", "data": "用户信息"	

	}
备注	

D.3 用户退出接口表

服务名称	https://auth.yjglt.jxx.cegn/api/login-out	
服务说明	用户退出	
请求方式	GET	
参数列表	参数名称	参数说明
	username	用户登录账号

附 录 E

（规范性附录）

服务接口调用类接口示例及说明

E.1 用户信息获取接口表

<table>
<tr><td>服务名称</td><td colspan="2">https://auth.yjglt.jxx.cegn/users/info</td></tr>
<tr><td>服务说明</td><td colspan="2">用户信息获取接口</td></tr>
<tr><td>请求方式</td><td colspan="2">POST</td></tr>
<tr><td rowspan="2">参数列表</td><td>参数</td><td>参数说明</td></tr>
<tr><td>Authorization</td><td>请求头携带令牌</td></tr>
<tr><td>返回值</td><td colspan="2">{
"code": 0,
"msg": null,
"data": {
"id": "33647",
"officeId": "2615",
"officeName": "研发中心",
"loginName": "张运康",
"password":
"7b7da2df1ffc33aed4dc3c3b6a11fb3e",
"no": "1505976563669",
"name": "张运康",
"email": "yangjun@chinauniwater.com",
"phone": "",
"mobile": "18507040603",
"remarks": "",
"userType": "",
"photo": "",</td></tr>
</table>

	"sex": "1", "mobileShort": "", "sort": 4587520, "position": "", "birthday": "", "room": "", "photoLarge": "", "photoSmall": "", "photoNormal": "", "idNo": "", "qqMulti": "", "weChat": "", "licence": "", "ipMulti": "", "officeAddress": "", "homeAddress": "", "homeTel": "", "alias": "", "password2": "xkq9+ZhvOIQneXdERohUwg==", "signature": "", "delFlag": "0", "loginFlag": "1", "access_token": "6f12d9ce-5f0c-4883-a8c1-b20de6bd5728", "refresh_token": "67aa3219-ef86-4dc5-95da-6c9bb8a9524d", "jwtToken": "eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiLmnajkv4oxIiwidXNlck lkIjoiMzM2NDciLCJuYW1lIjoi5p2o5L-KIiwidHlwZSI6InVzZX

	IiLCJleHAiOjE2MjMzMjYwOTl9.EZCjtkw6myfB9uSTddIBRnAei8iZKMtdsQDf-XjhdSdA4lgVwqguTpK6u-dK24zWChlkqHOUOONeT6qHNuTVehH9p7WtBxblBdlTP9S3gtmtSQYHSGeqy5MhEavs6uP9u4yMATEEBZWtZdfKwSZQGF9OpsL9SbMedXolcOhXvtk" } }

E.2 用户登录接口表

服务名称	https://auth.yjglt.jxx.cegn/users/login	
服务说明	用户登录，返回用户临时票据	
请求方式	POST	
参数列表	参数名称	参数说明
	username	用户名
	password	用户密码

返回值	{
	"code": 0,
	"msg": null,
	"data": {
	"umsAdmin": {
	"id": 33644,
	"companyId": null,
	"officeId": 2615,
	"loginName": "张运康",
	"password":
	"7b7da2df1ffc33aed4dc3c3b6a11fb3e",
	"no": "1505976470100",
	"name": "张运康",
	"email": "zhangyunkang@chinauniwater.com",	

	"phone": "", "mobile": "17779152309", "userType": "", "insider": "0", "photo": "/group1/M00/03/1A/CogGO185N_iAMbHxAAALhNPI8YE209.jpg", "loginIp": "10.36.253.102", "loginFlag": "1", "updateBy": 33644, "remarks": "", "delFlag": "0", "sex": "1", "mobileShort": null, "sort": 1170820574, "position": "", "birthday": "", "room": "", "photoLarge": "/group1/M00/03/1A/CogGO185N_iAZ6nBAAASv7HYINI370.jpg", "photoSmall": "/group1/M00/03/1A/CogGO185N_iAadToAAAF30vl0WU527.jpg", "photoNormal": "/group1/M00/03/1A/CogGO185N_iAMbHxAAALhNPI8YE209.jpg", "idNo": "", "qqMulti": "",

	"weChat": "", "licence": "", "ipMulti": "", "officeAddress": "", "homeAddress": "", "homeTel": "", "alias": "", "password2": "xkq9+ZhvOIQneXdERohUwg==", "signature": "", "deleteBy": null, "uuid": "bb70d056a1b145d3af539d7547fcbd9b", "officeUuid": "25cf9b013f744ca48172b76b11daf3f2", "commonToken": "eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiLlvKDov5DlurciLCJ1c2VySWQiOiIzMzY0NCIsIm5hbWUiOiLlvKDov5DlurciLCJ0eXBlIjoidXNlciIsImV4cCI6MTYyMzM3MjEzOX0.wUbxYgYf_Bkw98riVvqzLYNfEQGovNufhbEpCvgSqRfF7Kcw4EKVXcV4Cete_ORPviTNgZ2tmJxOSFJoiboObr3SCO63IUUcC-wKM52OyekKNBhWLkY3e1fclux5ikeUaeFnKlq75JAqDmvu74dXFvxarjf3covnqL7Cx1UPvaM" }, "resourceList": [] } }
备注	

附 录 F

（规范性附录）

应用系统登录/登出示例及说明

F.1 判断是否登录

待接入系统 A 前端依据前端 cookie 是否存在用户判断是否登录。

```
// 通过 cookie 判断用户是否登录
judgeUserLoginStatus() {
    var userCookie = app.getCookie("user");
    if (
        userCookie != null &&
        userCookie != undefined &&
        userCookie != ""
    ) {
        var userInfoStr = decodeURIComponent(userCookie);
        // console.log(userInfo);
        if (
            userInfoStr != null &&
            userInfoStr != undefined &&
            userInfoStr != ""
        ) {
            var userInfo = JSON.parse(userInfoStr);
            // 判断是否是一个对象
            if (typeof(userInfo) == "object") {
```

```
                this.userIsLogin = true;
                // console.log(userInfo);
                this.userInfo = userInfo;
            } else {
                this.userIsLogin = false;
                this.userInfo = {};
            }
        }
    } else {
        this.userIsLogin = false;
        this.userInfo = {};
    }
}
```

F.2 临时票据判断

系统 A 前端判断链接是否携带临时票据，如果携带则发送校验请求，如果不存在证明用户从未登录，则跳转登录页面。

```
if (!userIsLogin) {
    // 如果没有登录，判断一下是否存在 tmpTicket 临时票据
    var tmpTicket = app.getUrlParam("tmpTicket");
    console.log("tmpTicket: " + tmpTicket);
    if (tmpTicket != null && tmpTicket != "" && tmpTicket != undefined) {
        // 如果有 tmpTicket 临时票据，就携带临时票据发起请求到 cas 验证获取用户会话
        var serverUrl = app.serverUrl;
```

```
        axios.defaults.withCredentials = true;
        axios.post('http://www.sso.com:30971/verify-tmp-ticket?tmpTicket=' + tmpTicket)
            .then( res => {
                if(res.status === 200){
                    me.userInfo = res.data.data.umsAdmin;
                    console.dir(me.userInfo)
                    me.userIsLogin = true;
                    app.setCookie("user", JSON.stringify(me.userInfo));
                    window.location.href = "http://www.mtv.com:32064/index.html";
                }else {
                    alert(res.data.data.msg);
                    console.log(res.data.data.msg);
                }
            })
    } else {
        // 如果没有 tmpTicket 临时票据，说明用户从没登录过，那么就可以跳转至 cas 做统一登录认证了
        window.location.href = app.SSOServerUrl + "/login?returnUrl=http://www.mtv.com:32064/index.html";
    }
    console.log(app.SSOServerUrl + "/login?returnUrl=" + window.location);
}
```

F.3 SSO登录接口

SSO 登录接口，判断 cookie 中是否包含用户全局令牌，存在证明用户登录过，颁发临时令牌回跳，如果不存在则跳转登录页面。

```
@GetMapping("/login")
public String login(String returnUrl,
                    Model model,
                    HttpServletRequest request,
                    HttpServletResponse response) {
        model.addAttribute("returnUrl", returnUrl);
        // 1. 获取 userTicket 门票，如果 cookie 中能够获取到，证明用户登录过，此时签发一个一次性的临时票据并且回跳
        String userTicket = sysUserService.getCookie(request, COOKIE_USER_TICKET);
        boolean isVerified = sysUserService.verifyUserTicket(userTicket);
        if (isVerified) {
                String tmpTicket = sysUserService.createTmpTicket();
                return "redirect:" + returnUrl + "?tmpTicket=" + tmpTicket;
        }
        // 2. 用户从未登录过，第一次进入则跳转到 CAS 的统一登录页面
        return "login";
}
```

F.4 退出登录

当系统 A 退出系统时，调用统一平台上的退出接口，退出接口 url 为：host+/sso-logout,之后业务系统带上回调地址调用登录接口，或者根据自身业务要求回调到自身无需认证的页面。

```
@PostMapping("/sso-logout")
@ResponseBody
```

```
public R logout(@RequestParam("userId") String userId,
                HttpServletRequest request,
                HttpServletResponse response) throws Exception {
        AuthUserDetails auth = (AuthUserDetails) redisUtil.get(REDIS_USER_TOKEN+":"+userId);
        // 0. 获取 CAS 中的用户门票
        String userTicket = sysUserService.getCookie(request, COOKIE_USER_TICKET);
        redisUtil.del(REDIS_USER_TICKET + ":" + userTicket);
        // 1. 清除 userTicket 票据，redis/cookie
        deleteCookie(COOKIE_USER_TICKET, response);
        // 2. 清除用户全局会话（分布式会话）
        redisUtil.del(REDIS_USER_TOKEN + ":" + userId);
        if(auth==null){
                return R.ok();
        }
        String authToken=auth.getUmsAdmin().getCommonToken();
        //清除 token 相关数据
        jwtRedisUtil.deleteKey(authToken);
        jwtRedisUtil.hset("blacklist", authToken, DateUtil.getTime());
        //设置所有系统公共 token
        redisUtil.del(userId);
        return R.ok();
}
```

附 录 G

（规范性附录）

统一授权接入消息接口附录

G.1 基本消息体

参数名	说明	类型	备注
time	消息发送时间	String	yyyy-MM-dd HH:mm:ss 格式
type	消息类型	String	“301” 为新增角色消息类型
resourceId	资源 ID	Long	数据所属资源 ID
data	数据	String	对象，详见 1.4

G.2 人员对象

参数名	类型	说明	备注
alias	别名，当作厅邮箱账号	String	
birthday	生日	String	
email	邮箱	String	
homeAddress	家庭地址	String	
homeTel	家庭电话	String	
id	用户 ID	Long	
idNo	身份证号	String	
ipMulti	ip，多个用英文;分隔	String	
licence	车牌号	String	
loginFlag	是否允许登陆人员管理系统	String	
loginName	登录名	String	
mobile	手机号	String	
mobileShort	手机短号	String	
name	真实名称	String	
no	工号	String	
officeAddress	办公地址	String	
officeId	主部门 id	Long	

officeName	主部门名称	String	
password	密码 md5	String	
password2	密码 des	String	
phone	办公电话	String	
photo	头像	String	
photoLarge	大头像	String	
photoNormal	中等头像	String	
photoSmall	小头像	String	
position	职务	String	
qqMulti	qq 号，多个用英文;分隔	String	
remarks	备注	String	
room	房间号	String	
sex	性别	String	
signature	个性签名	String	
sort	排序	Long	
userType	用户类型	String	
viceOffices	从部门	array	ViceDeptMsg
officeId	部门 ID	Long	
officeName	部门名称	String	
sort	排序	Long	
weChat	微信号，多个用英文;分隔	String	

G.3 机构对象

参数名	类型	说明	备注
id	机构 ID	Long	
name	部门名称	String	
address	地址	String	
areaCode	所属区域 code	String	
areaName	所属区域	String	
code	部门编码（系统自动维护）	String	
email	邮箱	String	
fax	传真	String	
orgFlag	0:部门 1:机构	String	
parentId	父级 id	Long	

phone	电话	String	
primaryPerson	部门主管	String	
remarks	备注	String	
sort	部门排序	Long	
useable	是否可用(1:是;0:否)	String	
zipCode	邮编	String	

G.4 角色对象

参数名	类型	说明	备注
id	角色 id	Long	
code	角色编码	String	
name	名称	String	
externalCode	外部角色编码	String	
remark	备注	String	
resourceId	资源 ID	Long	
tenantId	租户 ID	Long	
type	角色类型： 1、资源模式角色 2、租户模式角色 3、租户模式公共角色	String	

G.5 角色菜单对象

参数名	类型	说明	备注
menuIds	菜单 id 集合	array	Long
roleId	角色 id	Long	

G.6 角色人员对象

参数名	类型	说明	备注
roleId	角色 id	Long	
userIds	人员 id 集合	array	Long

G.7 菜单对象

参数名	类型	说明	备注
id	菜单 id	Long	

code	编码	String	
icon	图标	String	
linkType	链接类型(1、内部链接 2、外部链接 3、其他)	String	
method	请求方式(1、GET 2、POST 3、PUT 4、DELETE)	String	
name	名称	String	
ownership	1、PC 端 2、移动端	String	
parentId	父节点	Long	
remarks	备注	String	
resourceId	资源 ID	Long	
sort	排序	Long	
type	类型(1、模块 2、菜单 3、按钮)	String	
url	资源路径	String	

G.8 租户对象

参数名	类型	说明	备注
code	租户编号	String	
id	租户 id	Long	
name	租户名称	String	
remarks	备注	String	
resourceId	资源 ID	Long	
status	状态	String	

G.9 租户菜单对象

参数名	类型	说明	备注
menuIds	菜单集合	array	Long
tenantId	租户 id	Long	

G.10 新增角色消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“301” 为新增角色消息类型
resourceId	Long	资源 ID	数据所属资源 ID

data	String	数据	对象，详见 1.4

G.11 修改角色消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“302” 为修改角色消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.4

G.12 删除角色消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“303” 为删除角色消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.4

G.13 新增角色菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“304” 为新增角色菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.5

G.14 删除角色菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“305” 为删除角色菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.5

G.15 新增角色人员消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式

type	String	消息类型	“306” 为新增角色人员消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.6

G.16 删除角色人员消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“307” 为删除角色人员消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.6

G.17 新增菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“401” 为新增菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.7

G.18 修改菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“402” 为修改菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.7

G.19 删除菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“403” 为删除菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.7

G.20 新增租户消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“501” 为新增租户消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.8

G.21 修改租户消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“502” 为修改租户消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.8

G.22 删除租户消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“503” 为删除租户消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.8

G.23 新增租户菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“504” 为新增租户菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.9

G.24 删除租户菜单消息

参数名	类型	说明	备注
time	String	消息发送时间	yyyy-MM-dd HH:mm:ss 格式
type	String	消息类型	“505” 为删除租户菜单消息类型
resourceId	Long	资源 ID	数据所属资源 ID
data	String	数据	对象，详见 1.9